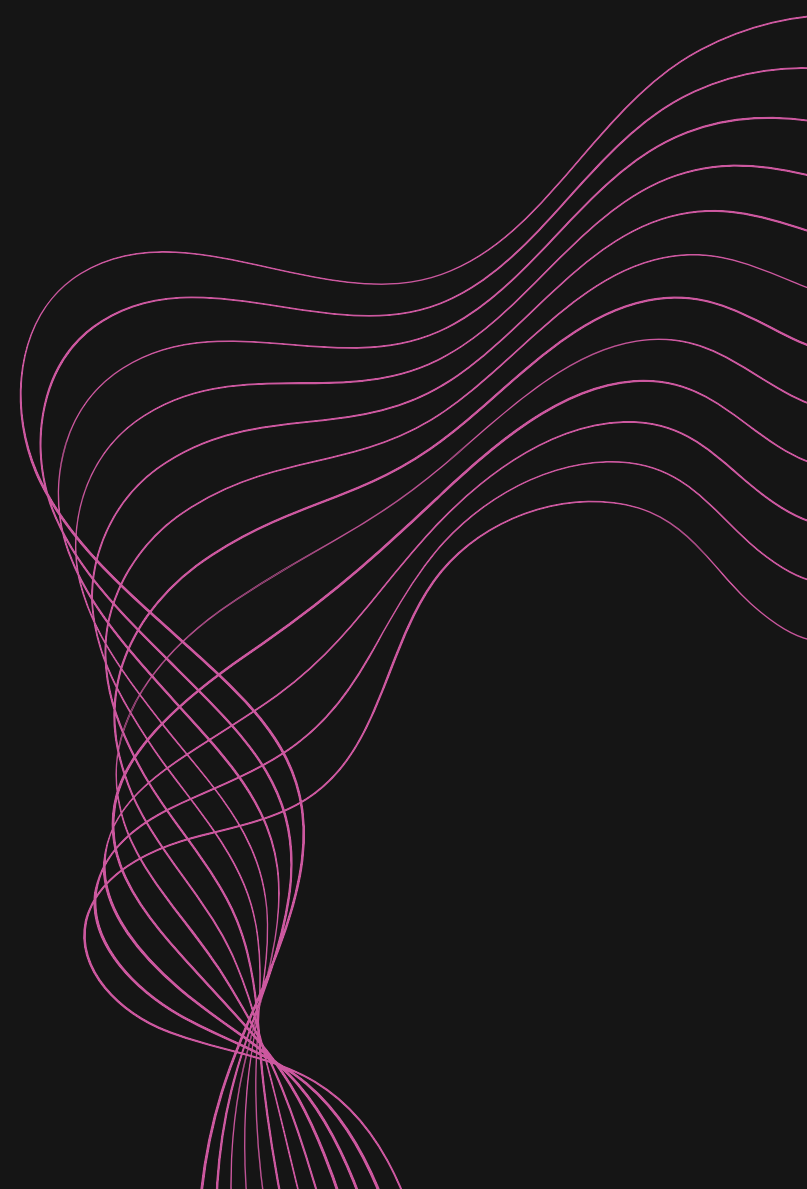




Cyber Security



WEEK 3

Charlotte Emma Whiting

CONTENT - WEEK 3

48-50

Q1.IT DEPARTMENT SCENARIO

51-52

Q2. SOCIAL ENGINEERING - TAILGATING EXPLANATION

53-54

Q3. JOHN THE RIPPER

55-58

Q4. FINDING THE FLAG

Q1 & 2. SOCIAL ENGINEERING



SOCIAL ENGINEERING

Definition

In the context of information security, social engineering is the psychological manipulation of people into performing actions or divulging confidential information. A type of confidence trick for the purpose of information gathering, fraud, or system access.

SCENARIO

You are an employee at a large corporation. You receive a phone call from someone claiming to be the IT helpdesk technician. They ask for your login credentials due to a "security upgrade." How would you respond in this situation?

This could potentially be a spoofing attempt or phishing, so in order to verify the information I would:

- Ask the caller to confirm their full name and the name of the exact department they are calling from. I would then explain that I will call them back to confirm identify. **It is important that you DO NOT call any number given, and that you use your own directory to make that call. This is because fake phone numbers have been known to be used to mimic legitimate departments.**
- Check to see if there has been any internal communications relating to the security update.
- Politely refuse to give any login credentials as I would be following security protocols.
- Inform my line manager/company of the call

SOCIAL ENGINEERING

EXAMPLE

There was a voice phishing attack on a UK-based CEO in 2019.

In 2019, the world of corporate espionage witnessed a novel and disturbing development – a voice phishing (vishing) attack that cost a UK-based energy firm a staggering €220,000!

The CEO of this firm, believing he was conversing with his boss, the chief executive of the German parent company and was skillfully deceived by a voice deepfake. The attacker, using sophisticated voice-generating AI, mimicked the German executive's voice and mannerisms with uncanny accuracy, compelling the CEO to transfer the hefty sum to a supposed Hungarian supplier.

This incident not only highlighted the financial risks associated with such scams but also raised alarms about the emerging threat of AI-driven impersonation in cybercrime.

SOCIAL ENGINEERING

WHAT IS TAILGATING?

Tailgating is a physical security breach where an unauthorised person tries to gain access to a secure premises by following an authorised person. It is one of the simplest forms of social engineering. An unauthorised person can gain access in a variety of ways:

- **Doors left open:** This could be anything from an employee propping the door open for air, or an authorised contractor keeping doors open to get supplies.
- **Praying on manners:** An unauthorised person asking an employee to 'Keep the door open please?' in order to gain access without any credentials
- **Waiting for an opportunity:** The authorised person doesn't secure the door behind them after entering and an unauthorised person could then grab the door before it closes.

Scenario

Kent Police HQ has multiple entrances, via a vehicle or via foot. Access is granted with either a pass or there is an intercom for visitors. You are asked to shut the gate/wait in your car until the gates close behind you then report to reception. Say you are entering via foot, and an unauthorised person could appear behind you and ask for you to hold the gate. They could even appear to have a staff lanyard on, to gain access to the grounds and you allow them to do so. This is tailgating.

SOCIAL ENGINEERING

● WHATS THE ISSUE?

There are many reasons why unauthorised access is an issue. From health and safety protocols to nefarious activity. The person in question could be a disgruntled employee, an opportunist or even someone set out to harm. In this scenario let's say someone, in this case a threat actor, wanted to get access to the HQ's computer systems. They've already managed to clone an access keycard using a flipper zero, granting access to the offices.

This could give them the opportunity to (but not limited too):

- **Installation:** Uploading malware to systems to disrupt police operations. This could be something that could take immediate effect or monitor systems for later use remotely.
- **Theft of assets:** Stealing hard drives and other storage devices, any evidence
- **Theft of data:** They could access the police database to steal data on police personnel, offenders, witness or victims and a wide range of other information.
- **Leaving devices:** A malicious device containing malware is switched out with a legitimate device with the intent that an authorised employee will use it causing disruption to systems.

There can be many reasons why a threat actor would do these things, the list is not exhausted

Q3.

JOHN THE RIPPER

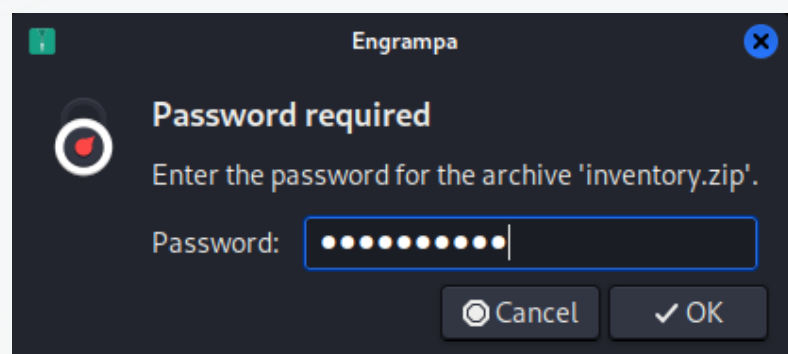


JOHN THE RIPPER

CRACKING THE PASSWORD FOR INVENTORY.ZIP

- **1st Step:** Right click on inventory.zip to open in terminal. Attempt to unzip inventory.zip using *unzip inventory.zip*
- **2nd Step:** We see it requires a password, so we use *zip2john inventory.zip > hash.txt* to convert the password hash stored in a ZIP file into a format that can be cracked
- **3rd Step:** We will then use the rockyou.txt list and bruteforce the password by *john hash.txt -wordlist=/usr/share/wordlists/rockyou.txt* to display the password

PASSWORD IS: **loveislife**



```
charlotteemmawhiting@kali: ~/Downloads
File Actions Edit View Help
zsh: corrupt history file /home/charlotteemmawhiting/.zsh_history

(charlotteemmawhiting@kali)-[~/Downloads]
$ unzip inventory.zip
Archive:  inventory.zip
  creating: inventory/
[inventory.zip] inventory/generic-protected.pdf password:
password incorrect--reenter:

(charlotteemmawhiting@kali)-[~/Downloads]
$ zip2john inventory.zip > hash.txt
ver 2.0 inventory.zip/inventory/ is not encrypted, or stored with n
on-handled compression type
ver 2.0 inventory.zip/inventory/generic-protected.pdf PKZIP Encr: c
mplen=28130, decmplen=30595, crc=C2393154 ts=70CD cs=c239 type=8
ver 2.0 inventory.zip/inventory/hackerdo.jpg PKZIP Encr: cmplen=119
9557, decmplen=1201665, crc=AA4FB55D ts=7102 cs=aa4f type=8
ver 2.0 inventory.zip/inventory/strings.txt PKZIP Encr: cmplen=373,
decmplen=633, crc=827FAF33 ts=7129 cs=827f type=8
NOTE: It is assumed that all files in each archive have the same pa
ssword.
If that is not the case, the hash may be uncrackable. To avoid this
, use
option -o to pick a file at a time.

(charlotteemmawhiting@kali)-[~/Downloads]
$ john hash.txt -wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 3 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
loveislife      (inventory.zip)
1g 0:00:00:00 DONE (2024-09-23 21:24) 25.00g/s 307200p/s 307200c/s
307200C/s horoscope..hawkeye
Use the "--show" option to display all of the cracked passwords rel
iably
Session completed.

(charlotteemmawhiting@kali)-[~/Downloads]
$
```

Q4.

FINDING THE FLAG



FINDING THE FLAG

Let's now unzip and extract the documents



```
(charlotteemmawhiting@kali)-[~/Downloads]
$ unzip inventory.zip -d extracted_inventory/
Archive:  inventory.zip
  creating:  extracted_inventory/inventory/
[inventory.zip] inventory/generic-protected.pdf password:
  inflating:  extracted_inventory/inventory/generic-protected.pdf
  inflating:  extracted_inventory/inventory/hackerdo.jpg
  inflating:  extracted_inventory/inventory/strings.txt
```

The generic-protected.pdf requires a password, so we need to use pdfcrack with a wordlist in order to crack the password!

```
found user-password: 'snowflake1'
```

```
(charlotteemmawhiting@kali)-[~/Downloads/extracted_inventory/inventory]
$ pdfcrack -f generic-protected.pdf -w rockyou.txt
PDF version 1.6
Security Handler: Standard
V: 2
R: 3
P: -4
Length: 128
Encrypted Metadata: True
FileID: 2e7fd9d50c8627e051a3562a991580da
U: f7d4f5260db25e26a1876d39eadb27eb28bf4e5e4e758a4164004e56fffa0108
O: 802f574047c8e36cf0d8056e057974ec92cdda549d92f24c6860882da5177cb4
found user-password: 'snowflake1'
```

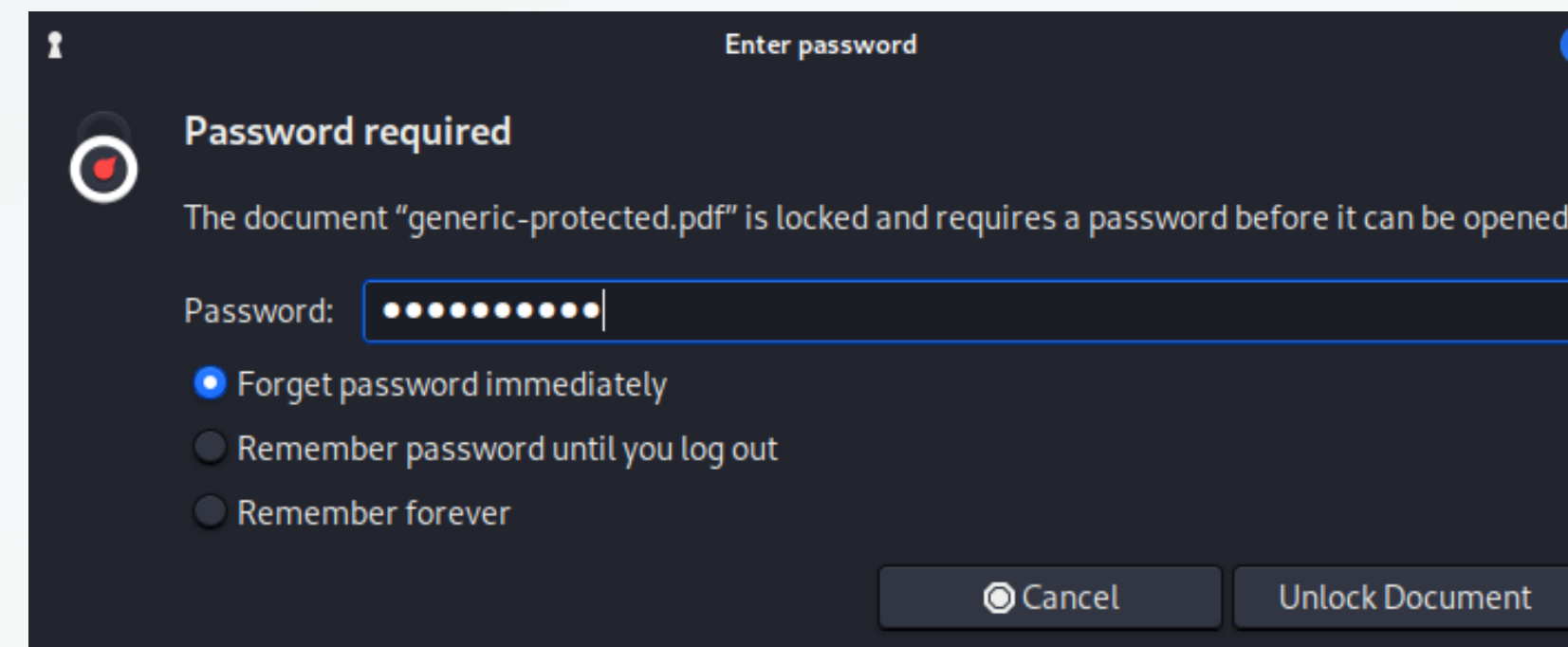
Now to find the flag using grep...but it looks like we can't use pdfgrep on password protected files :(



```
(charlotteemmawhiting@kali)-[~/Downloads/extracted_inventory/inventory]
$ pdfgrep -i "cgf" extracted_inventory/generic-protected.pdf
pdfgrep: Could not open extracted_inventory/generic-protected.pdf
```

FOUND THE FLAG!

But now we do have the password, we can just go to the file we downloaded, enter the password and capture the flag!



Congratulations!!!! 🎉

Here's your flag : `cfg{We3K_Pas5w0rds}`

Simple right? But why not try it another way...

USING GREP

You can decrypt the pdf by installing qpdf and creating a new decrypted pdf in order to use pdfgrep to search the file for the flags >
However, I had issues with that...

```
(charlotteemmawhiting@kali)-[~/Downloads/extracted_inventory/inventory]
$ sudo apt-get install qpdf
```

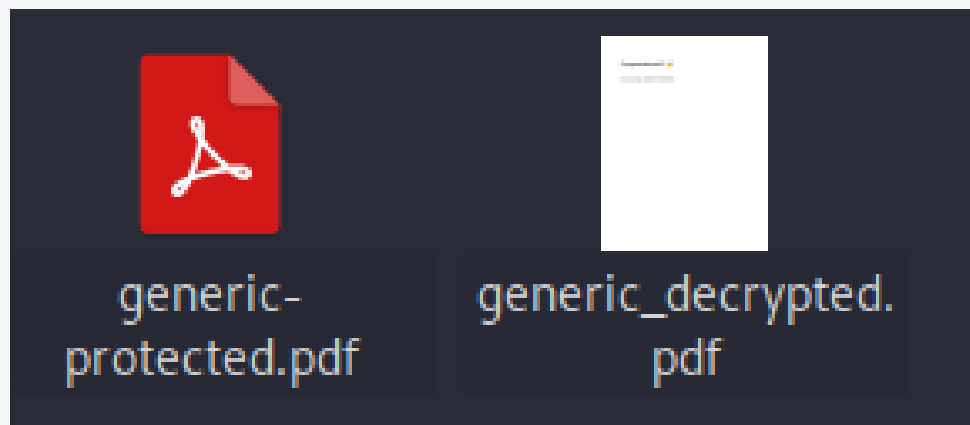
```
(charlotteemmawhiting@kali)-[~/Downloads/extracted_inventory/inventory]
$ qpdf --password=snowflake1 --decrypt generic-protected.pdf dgeneric-protected.pdf

(charlotteemmawhiting@kali)-[~/Downloads/extracted_inventory/inventory]
$ pdfgrep -i "cfg" dgeneric-protected.pdf
pdfgrep: Could not open dgeneric-protected.pdf
```

```
(charlotteemmawhiting@kali)-[~/Downloads/extracted_inventory/inventory]
$ sudo apt-get install pdftk
```

```
(charlotteemmawhiting@kali)-[~/Downloads/extracted_inventory/inventory]
$ pdftk generic-protected.pdf input_pw snowflake1 output generic_decrypted.pdf
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
Warning: Using a password on the command line interface can be insecure.
Use the keyword PROMPT to supply a password via standard input instead.
```

Next try, I installed pdftk instead and created a 'generic_decrypted.pdf' file which can be opened directly without a password...



OR, stay in the terminal and use pdfgrep to Capture the Flag!

```
(charlotteemmawhiting@kali)-[~/Downloads/extracted_inventory/inventory]
$ pdfgrep -i "cfg" generic_decrypted.pdf
Here's your flag : cfg{We3K_Pas5w0rds}
```

